

Joseph Flammia

OpenVAS Lab:

To start off, we will be installing OpenVAS on our Kali VM. To do this, we will need to first type the following commands into the terminal:

“**sudo apt update**”

“**sudo apt upgrade -y**”

“**sudo apt dist-upgrade -y**”

After installing the needed packages and dependencies, we can type “**apt install openvas**” to start the installation process.

```
root@kali:~# apt install openvas
Note, selecting 'gvm' instead of 'openvas'
Installing:
  gvm

Installing dependencies:
  greenbone-security-assistant  gsad  gvm-tools  libmicrohttpd12t64

Summary:
  Upgrading: 0, Installing: 5, Removing: 0, Not Upgrading: 1238
  Download size: 3,917 kB
  Space needed: 16.8 MB / 60.2 GB available

Continue? [Y/n] y
Get:5 http://mirrors.jevincanders.net/kali kali-rolling/main amd64 gvm-tools all 25.3.0-1 [160 kB]
Get:1 http://kali.download/kali kali-rolling/non-free amd64 greenbone-security-assistant all 25.3.1-0kali1 [3,455 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 libmicrohttpd12t64 amd64 1.0.2-2 [156 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 gsad amd64 24.2.3-1 [134 kB]
Get:4 http://kali.download/kali kali-rolling/main amd64 gvm all 25.04.0 [11.9 kB]
Fetched 3,917 kB in 1s (4,022 kB/s)
Selecting previously unselected package greenbone-security-assistant.
(Reading database ... 412631 files and directories currently installed.)
Preparing to unpack .../greenbone-security-assistant_25.3.1-0kali1_all.deb ...
Unpacking greenbone-security-assistant (25.3.1-0kali1) ...
Selecting previously unselected package libmicrohttpd12t64:amd64.
Preparing to unpack .../libmicrohttpd12t64_1.0.2-2_amd64.deb ...
Unpacking libmicrohttpd12t64:amd64 (1.0.2-2) ...
Selecting previously unselected package gsad.
Preparing to unpack .../gsad_24.2.3-1_amd64.deb ...
Unpacking gsad (24.2.3-1) ...
Selecting previously unselected package gvm.
Preparing to unpack .../archives/gvm_25.04.0_all.deb ...
Unpacking gvm (25.04.0) ...
Selecting previously unselected package gvm-tools.
Preparing to unpack .../gvm-tools_25.3.0-1_all.deb ...
Unpacking gvm-tools (25.3.0-1) ...
Setting up greenbone-security-assistant (25.3.1-0kali1) ...
Setting up libmicrohttpd12t64:amd64 (1.0.2-2) ...
Setting up gvm-tools (25.3.0-1) ...
Setting up gsad (24.2.3-1) ...
gsad.service is a disabled or a static unit, not starting it.
Setting up gvm (25.04.0) ...
Processing triggers for kali-menu (2025.2.7) ...
Processing triggers for libc-bin (2.41-6) ...
Processing triggers for man-db (2.13.1-1) ...
```

```
root@kali:~#
```

The next step is to run the installer and set up OpenVAS. To do this, enter command “gvm-setup” as pictured below. This process may take some time, as there are over 50,000 NVT’s to be installed during the process.

```
gvm-setup
This script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali

[>] Starting PostgreSQL service
[>] Creating GVM's certificate files
[>] Creating PostgreSQL database
[*] Creating database user
[*] Creating database
[*] Creating permissions
CREATE ROLE
[*] Applying permissions
GRANT ROLE
[*] Creating extension uuid-osspl
CREATE EXTENSION
[*] Creating extension pgcrypto
CREATE EXTENSION
[*] Creating extension pg-gvm
CREATE EXTENSION
[>] Migrating database
[>] Checking for GVM admin user
[*] Creating user admin for gvm
[*] Please note the generated admin password
[*] User created with password 'bd9540e8-6879-4002-856b-55c1a34d0ea4'.
[*] Configure Feed Import Owner
[*] Define GVM feeds
[*] Update GVM feeds
Running as root. Switching to user '_gvm' and group '_gvm'.
Trying to acquire lock on /var/lib/openvas/feed-update.lock
Acquired lock on /var/lib/openvas/feed-update.lock
  Downloading Notus files from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/notus/ to /var/lib/notus
  Downloading NASL files from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/nasl/ to /var/lib/openvas/plugins
Releasing lock on /var/lib/openvas/feed-update.lock
Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
  Downloading SCAP data from rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/scap-data/ to /var/lib/gvm/scap-data
```

Once the installation is complete as indicated by the message omitted here:

```
[+] Done
[*] Please note the password for the admin user
[*] User created with password 'bd9540e8-6879-4002-856b-55c1a34d0ea4'.

[>] You can now run gvm-check-setup to make sure everything is correctly configured

(root@kali)-[/home/kali]
```

We can verify that the installation was successful with the command “gvm-check-setup”. If everything was successful, you should get something like the output below:

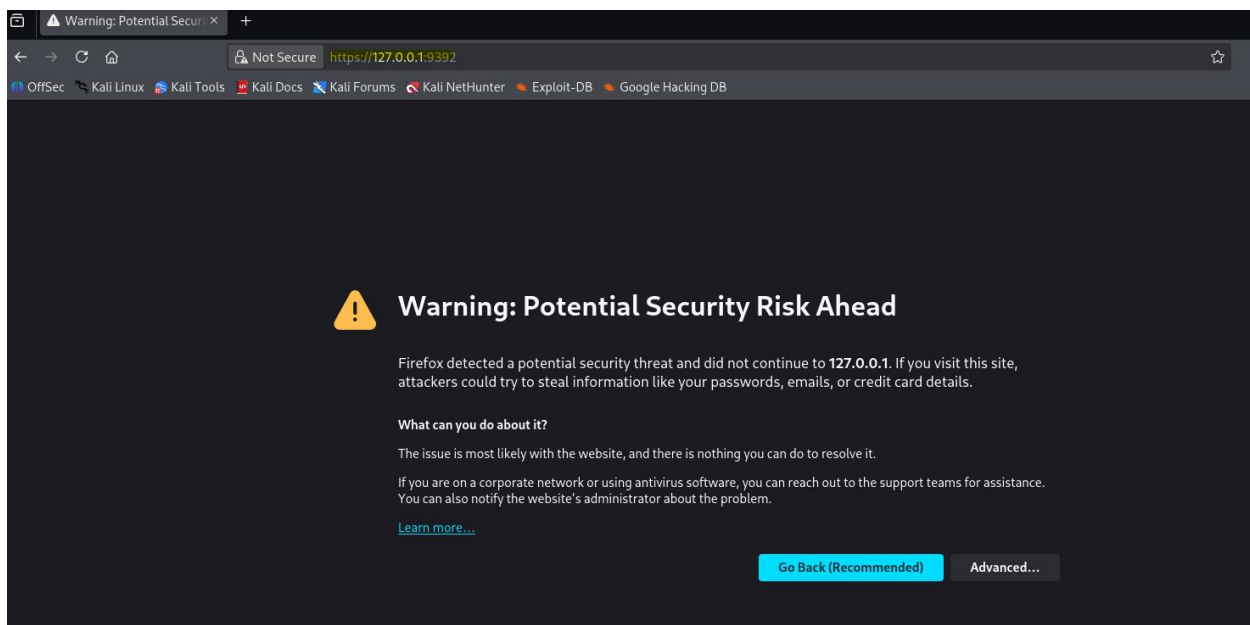
```

OK: _gvm owns all files in /var/lib/openvas/gnupg
OK: redis-server is present.
OK: scanner (db.address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
OK: the mqtt_server.uri is defined in /etc/openvas/openvas.conf
OK: _gvm owns all files in /var/lib/openvas/plugins
OK: NVT collection in /var/lib/openvas/plugins contains 94689 NVTs.
OK: The notus directory /var/lib/notus/products contains 505 NVTs.
Checking that the obsolete redis database has been removed
Could not connect to Redis at /var/run/redis-openvas/redis-server.sock: No such file or directory
OK: No old Redis DB
Starting ospd-openvas service
Waiting for ospd-openvas service
OK: ospd-openvas service is active.
OK: ospd-OpenVAS is present in version 22.9.0.
Step 2: Checking GVMDB Manager ...
OK: GVM Manager (gvmdb) is present in version 26.0.0.
Step 3: Checking Certificates ...
OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
OK: SCAP data found in /var/lib/gvm/scap-data.
OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking PostgreSQL DB and user ...
OK: PostgreSQL version and default port are OK.
gvmdb | _gvm | UTF8 | libc | en_US.UTF-8 | en_US.UTF-8 | |
16436|pg-gvm|10|2200|f|22.6||
OK: At least one user exists.
Step 6: Checking Greenbone Security Assistant (GSA) ...
OK: Greenbone Security Assistant is present in version 24.2.3-git.
Step 7: Checking if GVM services are up and running ...
Starting gvmdb service
Waiting for gvmdb service
OK: gvmdb service is active.
Starting gsad service
Waiting for gsad service
OK: gsad service is active.
Step 8: Checking few other requirements ...
OK: nmap is present.
OK: ssh-keygen found, LSC credential generation for GNU/Linux targets is likely to work.
OK: nsis found, LSC credential package generation for Microsoft Windows targets is likely to work.
OK: xsltproc found.
WARNING: Your password policy is empty.
SUGGEST: Edit the /etc/gvm/pwpolicy.conf file to set a password policy.
Step 9: Checking greenbone-security-assistant ...
OK: greenbone-security-assistant is installed

It seems like your GVM-25.04.0 installation is OK.

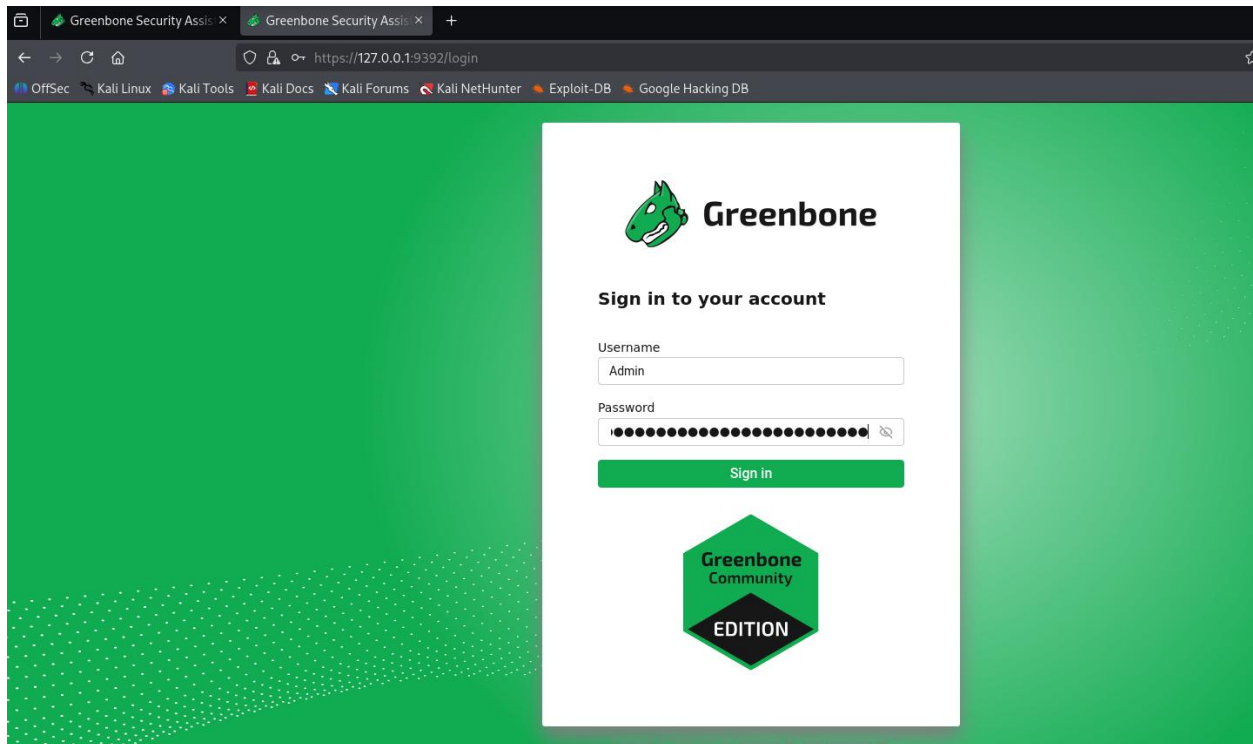
```

Now that we have confirmed OpenVAS is working as intended, we can access the GSA webpage using a browser on our VM. Here, I used Firefox and then typed in “127.0.0.1:9392” to access the webpage.

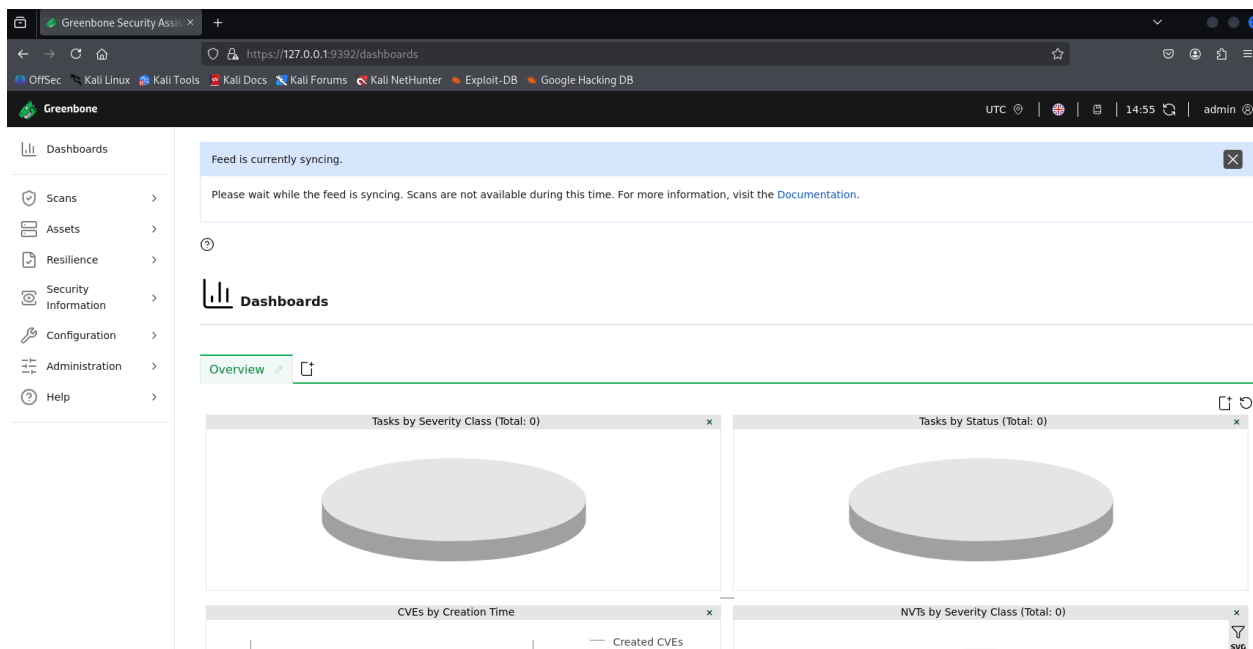


After accessing the webpage, click “advanced,” “accept risk,” and then you will be greeted with the login page for GSA.

To login, simply use the login information for the “Admin” account that was automatically generated when installing before

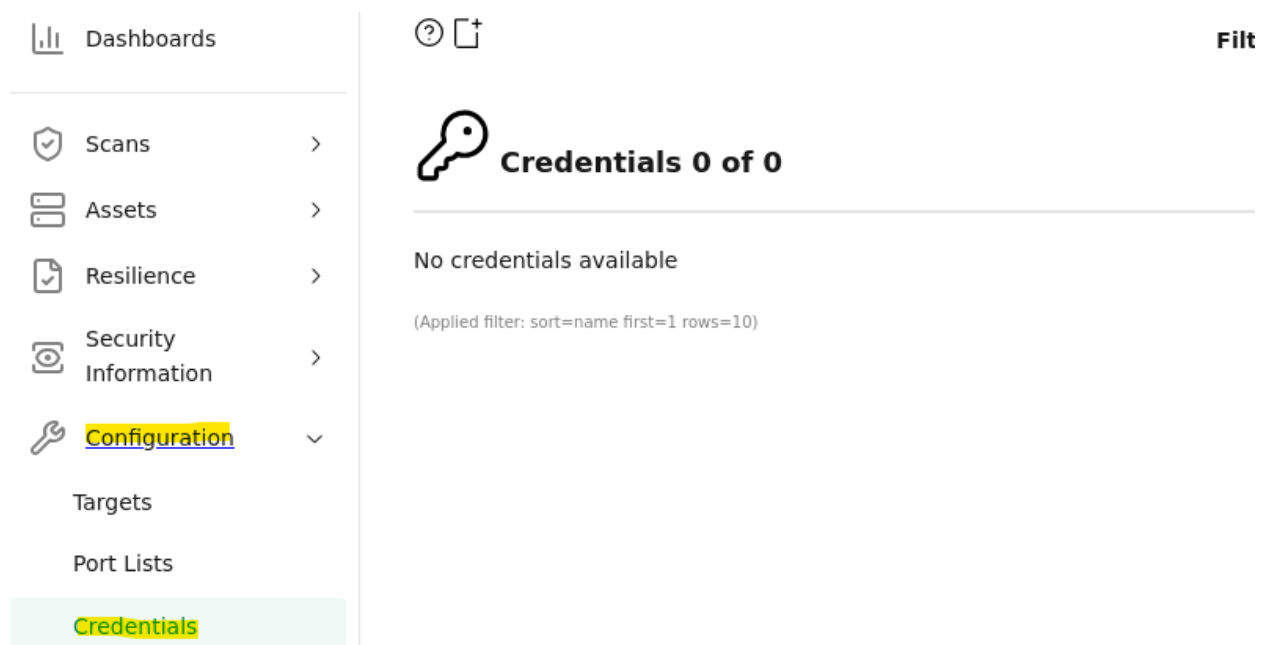


After logging in, we will be greeted with the Greenbone dashboard home page.

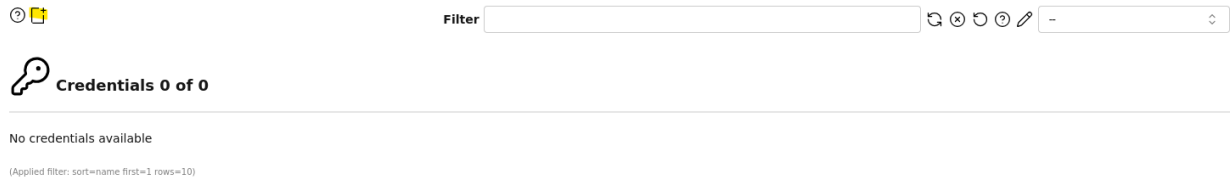


From here, we are going to add credentials to Greenbone to help us during our scans.

To do this, simply navigate to the left-hand side of the dashboard, click “Configuration,” and then “Credentials” in the drop-down menu.



From here, click on the top left symbol next to the question mark to add the credentials.



Doing so will create a new window where we can enter some information such as a name, comments, and of course the username/password.

As pictured below, I entered the username and password of the Windows Server VM and then saved it.

New Credential



Name

Windows Server 2022 Credentials

Comment

Type

Username + Password



Allow insecure use

☐ Yes ☐ No

Auto-generate

☐ Yes ☒ No

Username

Administrator

Password

Pa22w0rd



Cancel

Save



Credentials 1 of 1



1 - 1 of 1

Name	Type	Allow insecure use	Login	Actions
Windows Server 2016 Credentials	Username + Password (up)	No	Administrator	



Comment

Type Username + Password (up)

Allow Insecure Use No

Login Administrator

Apply to page contents

(Applied filter: sort=name first=1 rows=10)

1 - 1 of 1

Next up, we will add a target for our scans using the dashboard again. The process is remarkably similar to adding credentials. Simply navigate to the dashboard, click configurations, and then “targets.”

From here, we will need to add two things. First obviously being the IP of the Windows server, aka our target.

New Target



Name

GCPG Server

Comment

Hosts



Manual

192.168.23.130



From file



Exclude Hosts



Manual



From file



Allow simultaneous scanning via multiple IPs



Yes



No

Port List

All IANA assigned TCP



Alive Test

Cancel

Save

There are a few other options you can find by scrolling down; however, we are only focused on the “SMB” option. For this option, we will choose the credential information that we created previously for the scan to use. Additionally, I named the target “GCPG Server.”

After we have saved our credential information and created our host information, we can now start to create the scan.

New Target



Alive Test

Scan Config Default



Credentials for authenticated checks

SSH

--



on port

22



SMB (NTLM)

Windows Server 2016 Credentials



ESXi

--



SNMP

--



Reverse Lookup Only



Yes



No

Reverse Lookup Unify



Yes

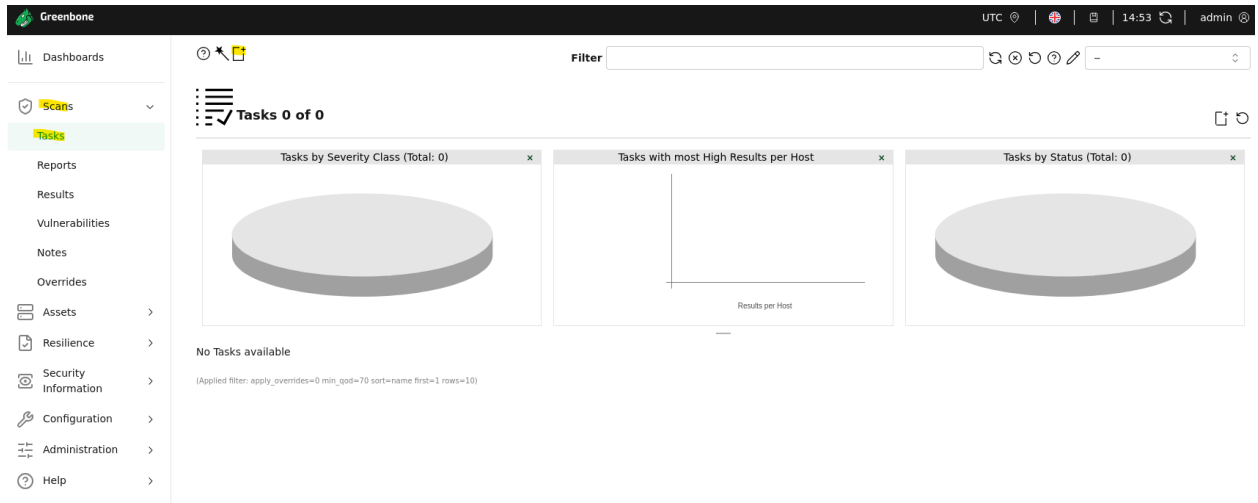


No

Cancel

Save

To do this, go back to the dashboard and click “scans,” “tasks,” and then click the plus sign at the top left just as before.



Once in the “New Task” window, we can start to create the outlines for our scan.

As pictured below, I named the task “GCPG Server Scan,” and selected the target “GCPG Server”, as named before.

New Task



Name

GCPG Server Scan

Comment

Scan Targets

GCPG Server



Alerts



Schedule

--



Once



Add results to Assets



Yes



No

Apply Overrides



Yes



No

Min QoD

7n



Cancel

Save

Towards the end of the window, ensure that the scan config is set to “Full and Fast.” Everything else may be left to the default settings. After configuring, click save.

New Task



Alterable Task

☐ Yes ☒ No

Auto Delete Reports

☒ Do not automatically delete reports

☐ Automatically delete oldest reports but always keep newest

5

reports

Scanner

OpenVAS Default

Scan Config

Full and fast

Order for target hosts

Sequential

Maximum concurrently executed NVTs per host

4

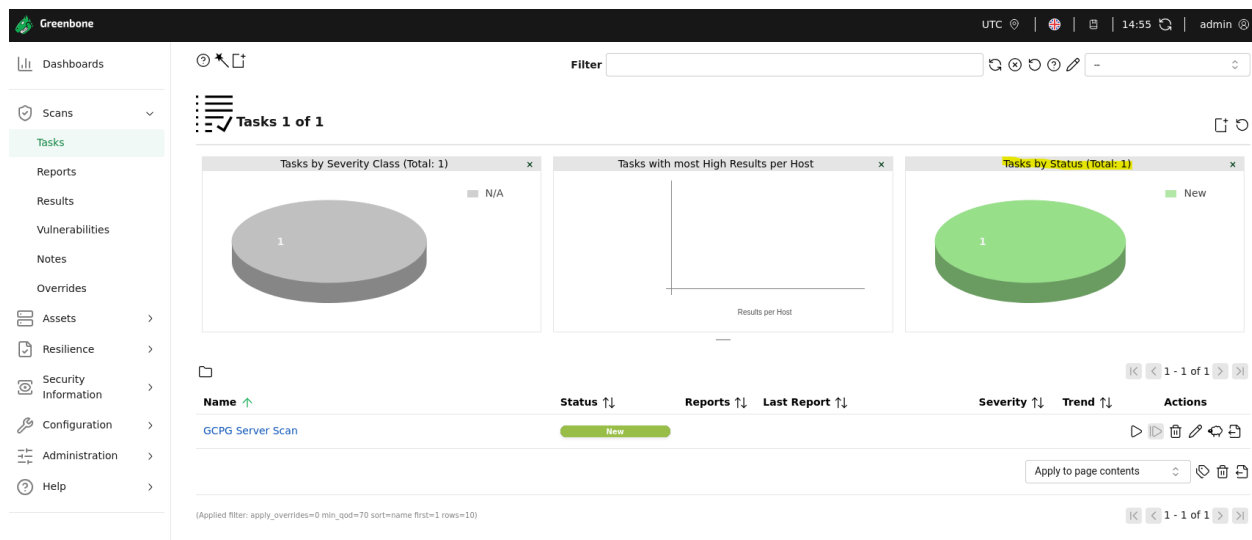
Maximum concurrently scanned hosts

20

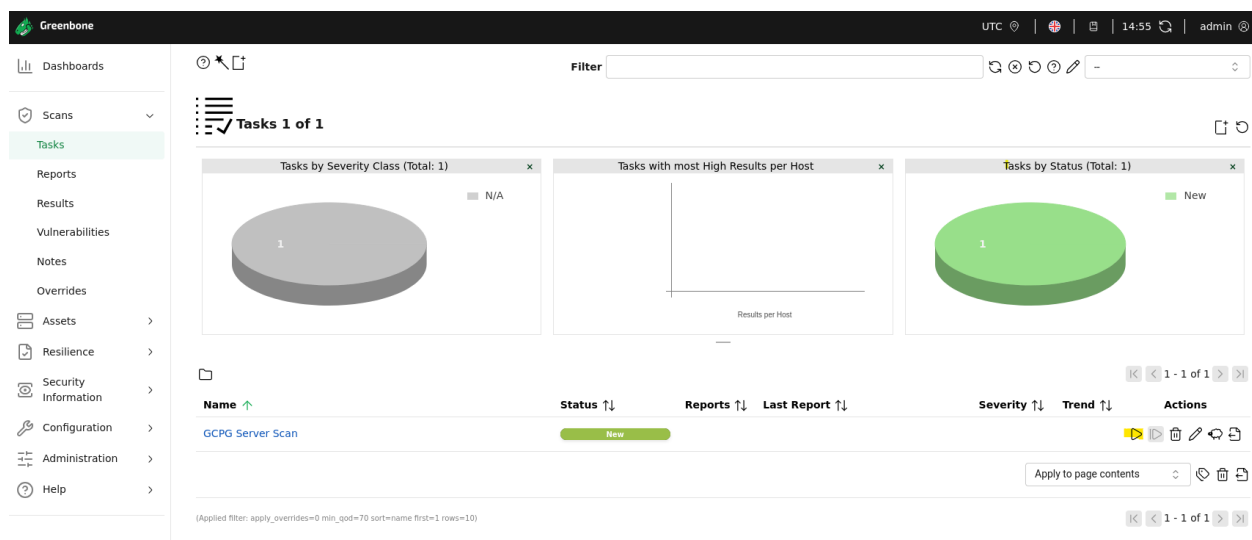
Cancel

Save

After saving, we can see that we have a new task, as indicated by the green chart below:



Now we can finally start our scan. To do this, click the start button located towards the bottom right, under “Actions.”



We can see the scan is in progress due to the “request” status as pictured below:

Name	Status	Reports	Last Report	Severity	Trend	Actions
GCPG Server Scan	Requested	2				[Play] [Stop] [Refresh] [Download]

(Applied filter: apply_overrides=0 min_qod=70 sort=name first=1 rows=10)

The scan may take several minutes to complete. However, once done you will see the status will have changed to “Done.” To check the results, click the number under “reports.”

Name ↑	Status ↑↓	Reports ↑↓	Last Report ↑↓	Severity ↑↓	Trend ↑↓	Actions
GCPG Server Scan	Done	2	Tue, Oct 7, 2025 1:11 AM Coordinated Universal Time	10.0 (High)		    
Apply to page contents   						

From here, we will be able to see what the scan uncovered. There are tons of pieces of information about the system we scanned and its vulnerabilities now.

Dashboards

Scans

Tasks

Reports

Results

Vulnerabilities

Notes

Overrides

Assets

Resilience

Security Information

Configuration

Administration

Help

Tue, Oct 7, 2025 1:12 AM

Report: Coordinated Universal Time

Done

4199a707-00c3-41eb-83d9-8c2c2964105a

Created: Tue, Oct 7, 2025 1:12 AM Coordinated Universal Time

Modified: Tue, Oct 7, 2025 1:43 AM Coordinated Universal Time

Owner: admin

Information

Results (139 of 230)

Hosts (1 of 1)

Ports (7 of 13)

Applications (14 of 14)

Operating Systems (1 of 1)

CVEs (130 of 130)

Closed CVEs (147 of 33)

TLS Certificates (1 of 1)

Error Messages (1 of 1)

User Tags (0)

1 - 100 of 139

Vulnerability ↑↓	Severity ↓	QoD ↑↓	Host IP ↑↓	Name ↑↓	Location ↑↓	EPSS Score ↑↓	Percentile ↑↓	Created ↑↓
Microsoft Windows Multiple Vulnerabilities (KB4565511)	10.0 (High)	80 %	192.168.23.130		general/tcp	N/A	N/A	Tue, Oct 7, 2025 1:26 AM Coordinated Universal Time
Microsoft Windows Multiple Vulnerabilities (KB4571694)	10.0 (High)	80 %	192.168.23.130		general/tcp	N/A	N/A	Tue, Oct 7, 2025 1:26 AM Coordinated Universal Time

We can examine each of these vulnerabilities for a detailed description of. For example, let us look at the “KB4565511” vulnerability.

Information	Results (139 of 230)	Hosts (1 of 1)	Ports (7 of 13)	Applications (14 of 14)	Operating Systems (1 of 1)	CVEs (130 of 130)	Closed CVEs (147 of 33)	TLS Certificates (1 of 1)	Error Messages (1 of 1)	User Tags (0)
1 - 100 of 139										
Vulnerability 	 Severity 	QoD 	Host IP 	Name 	Location 	EPSS Score 	Percentile 	Created 		
Microsoft Windows Multiple Vulnerabilities (KB4565511)	 10.0 (High)	80 %	192.168.23.130		general/tcp	N/A	N/A	Tue, Oct 7, 2025 1:26 AM Coordinated Universal Time		

Clicking the vulnerability will reveal information such as what the vulnerability is, a description of what the vulnerability is a direct cause of, and even an impact/solution for it.

Summary

This host is missing a critical security update according to Microsoft KB4565511

Detection Result

Vulnerable range: 10.0.14393.0 - 10.0.14393.3807
File checked: C:\Windows\system32\Gdiplus.dll
File version: 10.0.14393.321

Insight

Multiple flaws exist due to:

- Windows Domain Name System servers fail to properly handle requests (SIGRed, CVE-2020-1350).
- Windows System Events Broker fails to properly handle file operations.
- Windows WalletService fails to properly handle objects in memory.
- Windows Runtime fails to properly handle objects in memory.
- Windows Jet Database Engine fails to properly handle objects in memory.
- Windows Network Connections Service fails to properly handle objects in memory.

Impact

Successful exploitation will allow an attacker to execute arbitrary code, elevate privileges, disclose sensitive information and denial of service attacks.

Solution

Solution Type:  Vendorfix

The vendor has released updates. Please see the references for more information.